

Universitas Udayana (UNUD) — Web Security Review

Tanggal: 18 Juni 2026

Reviewer: Afiq Andico, mahasiswa Program Studi Sistem Informasi, STIKOM Bali

Target: <https://www.unud.ac.id/>

Metode: Static analysis saja — HTTP header inspection, HTML/JS source reading, public endpoint probing

Cakupan: Public surface only (homepage, common WordPress endpoints). Area authenticated tidak termasuk scope.

Ringkasan Eksekutif

UNUD website berjalan di **WordPress 6.9** (versi terbaru) di nginx/Ubuntu. Fondasi keamanan sudah ada (X-Frame-Options, X-Content-Type-Options, Referrer-Policy) — **tapi ada gap signifikan** di defense in depth dan information disclosure yang perlu diperbaiki.

Severity	Count	Items
Notable	1	Username enumeration via wp-json (5 username exposed, termasuk admin)
Medium	4	Missing HSTS, CSP, Permissions-Policy; server version exposed
Low	1	WordPress version disclosure (readme.html)

Tidak ada exploit path yang verified dari public surface. Semua temuan dari static analysis. Tujuan: bahan evaluasi internal UNUD IT.

1. Tech Stack Terdeteksi

```
WordPress 6.9 (rilis akhir 2024, versi terbaru)
nginx 1.28.0 di Ubuntu
PHP (versi tidak exposed di headers)
Custom theme: unud-theme-2026
JS: Alpine.js, custom app-*.js, iconify.min.js, aos.js
CSS: Inter, aos.css, all.min.css (FontAwesome)
```

WordPress 6.9 = versi terbaru — UNUD update secara berkala, ini positif.

2. Security Headers Analysis

Bukti reproduksi:

```
curl -sI https://www.unud.ac.id/ | grep -iE "x-frame|x-content|referrer|strict-transp
```

Hasil:

Header	Status	Catatan
X-Frame-Options: SAMEORIGIN	✓ Present	Clickjacking protection
X-Content-Type-Options: nosniff	✓ Present	MIME sniffing protection
Referrer-Policy: strict-origin-when-cross-origin	✓ Present	Modern default
Strict-Transport-Security	✗ MISSING	HTTPS-only enforcement tidak ada
Content-Security-Policy	✗ MISSING	No XSS defense in depth
Permissions-Policy	✗ MISSING	Modern API restrictions
X-XSS-Protection	✗ Not present	Deprecated, browser modern ignore

Catatan penting:

- Untuk situs sebesar UNUD dengan traffic tinggi, **HSTS wajib** — tanpa HSTS, attacker bisa downgrade attack ke HTTP.
- **CSP critical** — WordPress sites dengan banyak plugin rentan XSS tanpa CSP defense in depth.

3. TEMUAN: WordPress User Enumeration via REST API

Severity: Low–Medium (4.0)**Tipe:** Information Disclosure**Bukti reproduksi:**

```
curl -s https://www.unud.ac.id/wp-json/wp/v2/users
```

Hasil (5 user accounts exposed):

Display Name	Slug (username)
Admin Web Universitas Udayana	admin_unud
Biro Akademik, Kerjasama, dan Hubungan Masyarakat (BAKH)	madewardana
Biro Akademik, Kerjasama, dan Hubungan Masyarakat (BAKH)	ayusdivira
purnama.nyoman	purnama-nyoman
suwija_putra	putrasuwija

Catatan:

- Akun `admin_unud` kemungkinan besar adalah administrator web — target utama untuk targeted attack.
- WordPress secara default meng-expose user enumeration via REST API sejak versi 4.7.
- Bisa dikombinasikan dengan targeted phishing ("dari admin UNUD").

Fix (di `functions.php` theme, atau via plugin):

```
// Opsi 1: Disable REST API for unauthenticated users
add_filter('rest_endpoints', function($endpoints) {
    if (!is_user_logged_in()) {
        if (isset($endpoints['/wp/v2/users'])) {
            unset($endpoints['/wp/v2/users']);
        }
        if (isset($endpoints['/wp/v2/users/(?P<id>[\d]+)'])) {
            unset($endpoints['/wp/v2/users/(?P<id>[\d]+)']);
        }
    }
    return $endpoints;
});

// Opsi 2: Via plugin (lebih mudah)
// Install: "Disable WP REST API" atau "WP Hide REST API"
```

4. 🟡 TEMUAN: Security Headers Hilang (HSTS, CSP, Permissions-Policy)

Severity: Medium (5.0)

Lokasi: Semua halaman UNUD (global, di level nginx/Apache)

Header yang HILANG:

Header	Rekomendasi
Strict-Transport-Security	<code>max-age=31536000; includeSubDomains; preload</code>
Content-Security-Policy	<code>default-src 'self'; script-src 'self' 'unsafe-inline'; style-src 'self' 'unsafe-inline' https://fonts.googleapis.com; img-src 'self' data: https:; font-src 'self' https://fonts.gstatic.com; connect-src 'self'; frame-ancestors 'self';</code>
Permissions-Policy	<code>geolocation=(), camera=(), microphone=()</code>

Fix untuk nginx (yang UNUD pakai):

```
# /etc/nginx/sites-available/unud.ac.id.conf
add_header Strict-Transport-Security "max-age=31536000; includeSubDomains; preload" always;
add_header Content-Security-Policy "default-src 'self'; script-src 'self' 'unsafe-inline' https://fonts.googleapis.com; style-src 'self' 'unsafe-inline' https://fonts.gstatic.com; img-src 'self' data: https:; font-src 'self' https://fonts.gstatic.com; connect-src 'self'; frame-ancestors 'self';" always;
add_header Permissions-Policy "geolocation=(), camera=(), microphone=()" always;
```

Catatan: HSTS perlu waktu untuk ter-enforce penuh (browser caching). Submit ke <https://hstspreload.org> setelah tested.

5. ● TEMUAN: Server Version Disclosure (nginx 1.28.0)

Severity: Low (3.0)

Bukti:

```
curl -sI https://www.unud.ac.id/ | grep "Server:"
# Server: nginx/1.28.0 (Ubuntu)
```

Catatan: Mengekspos specific version membantu attacker mencari CVE untuk versi tersebut.

Fix (`/etc/nginx/nginx.conf`):

```
server_tokens off;
```

6. ● TEMUAN: WordPress Version Disclosure (readme.html)

Severity: Low (2.5)

Bukti:

```
curl -sL https://www.unud.ac.id/readme.html
# Mentions WordPress + version in body
```

readme.html WordPress secara default mention versi yang digunakan. Untuk UNUD (6.9), attacker tahu persis versi.

Fix:

```
# Remove readme.html (WordPress includes it by default)
rm /path/to/wordpress/readme.html

# Atau via nginx (tidak perlu hapus file):
location = /readme.html { deny all; }
location = /license.txt { deny all; }
```

7. Other Findings (Informational)

Item	Status	Catatan
<code>/wp-login.php</code>	404 Not Found	Mungkin di-rename atau WAF rule. Tidak bisa probe lebih lanjut.
<code>/wp-admin/</code>	302 Redirect	Redirect ke login (normal)
<code>/xmlrpc.php</code>	405 Method Not Allowed	Method disabled (bagus)
<code>/wp-cron.php</code>	200 OK	Normal, tapi expose cron trigger
<code>/wp-config-sample.php</code>	500 Error	Server error (config issue)
<code>/robots.txt</code>	404 Not Found	Tidak ada robots.txt
<code>/sitemap.xml</code>	301 Redirect	Redirect ke sitemap generator (Yoast/All-in-One SEO)
Inline event handlers (9 found)	Low	Alpine.js conventions, likely safe tapi worth audit
Forms (1 only)	Search form (GET)	Tidak ada form login di public page
XSS patterns	Not significant	Hanya <code>innerHTML</code> di Alpine.js (sandboxed by framework)

8. Rekomendasi Prioritas

Immediate (1-2 jam)

1. Disable WP REST API user enumeration (paling critical)
2. Tambah HSTS header
3. Tambah CSP header

Short-term (1-2 minggu)

4. Tambah Permissions-Policy
5. Hide server version (`server_tokens off`)
6. Remove atau block `readme.html` , `license.txt`

Medium-term (1-3 bulan)

7. WordPress security audit lengkap (dengan authorization):
 - Plugin vulnerability check (WPScan)
 - Theme vulnerability check
 - User password policy review
8. Implement Web Application Firewall (Cloudflare, ModSecurity, etc.)
9. Implement login rate limiting
10. Implement 2FA untuk admin accounts
11. HSTS preload submission

Long-term

12. Pertimbangkan hosting migration ke managed WordPress (WP Engine, Kinsta) untuk better security defaults
 13. Implement Content-Security-Policy-Report-Only mode untuk gradual rollout
 14. Regular security audit cycle (quarterly)
-

9. Yang TIDAK Saya Verifikasi (perlu dicek internal UNUD IT)

Area	Yang perlu dicek
WordPress plugins	Versi dan vulnerability. WPScan dengan authorization.
WordPress theme	Custom code audit. Theme <code>unud-theme-2026</code> perlu review.
Admin password policy	Minimum complexity, rotation, dll?
Login rate limiting	Brute force protection? (login 404 suggests hidden, but not tested)
Database credentials	wp-config.php security
Backup	Backup encrypted? Offsite?
2FA	Untuk admin accounts?
Audit logging	Log admin actions?
Plugin auto-update	WordPress 6.9 fitur ini, diaktifkan?
User roles & capabilities	Least privilege diterapkan?

10. Etika Pengujian

Saya hanya melakukan static analysis — **tidak ada eksploitasi atau active testing**:

- ✓ HTTP header inspection (no payload submission)
- ✓ HTML/JS source reading (no exploitation)
- ✓ Public endpoint probing (no authentication bypass attempt)
- ✗ Tidak login attempt dengan credentials apapun
- ✗ Tidak submit form dengan crafted input
- ✗ Tidak brute force atau password spraying
- ✗ Tidak test SQLi/XSS dengan payload

Tujuan 100% konstruktif: bahan evaluasi internal UNUD IT, bukan exploit disclosure.

11. Kontak

Afiq Andico

Mahasiswa Program Studi Sistem Informasi
STIKOM Bali

- Email: afiqandico13@gmail.com
- WhatsApp: 08990308936
- GitHub: [@afiqandico13](#)

Saya terbuka untuk diskusi lebih lanjut atau klarifikasi tentang temuan ini.